

Lecture 24

Industry Perspective - Part 03

Cyber Security and Privacy | NPTEL 106106248

Prof. Saji K. Mathew, IIT Madras

Video: <https://www.youtube.com/watch?v=JPQiuqw6fvw>

Study transcript from publicly available YouTube captions. Course content and video rights belong to NPTEL / IIT Madras. For personal study only.

sorry this is good afternoon and welcome to this live interaction as a part of the cyber security and privacy course this week is the week for risk management and I noticed that your video sir already available and along with of course the slides that have been used and risk management is a very very important topic as far as cyber security is concerned it discusses the management perspective of cyber security and in particular the cyber security management is dependent on how well you are able to understand risk involved so there are different approaches to assessing cyber risk or risk in general and I follow your textbook which is very applied way of understanding or measuring and then using the measure of risk as a basis to control risk okay and the control mechanisms for risk are discussed after risk has been assessed so you would become familiar with the risk management process which starts with risk identification okay the refaces as you see there is risk identification risk assessment assessment here meaning measurement and then third is risk control okay or how do you act on act on managing controlling or reducing your risk based on the measures that has come up so you know as we generally say in in controls that which you cannot measure you cannot control okay so the first step towards control is measurement if you know using some objective measure what are the risks involved then you can control it you can act on it you know so for example your learning is something that we try towards us you know every week use using an instrument called an assignment okay or a short examination okay and you get some score on it okay that score of course typically in a classroom come to the instructor and also go to the students okay so using that measure you know how you are performing okay and if it's a low score you you come to understand that you need to put more effort okay to improve your scores okay score in itself is not important but learning is important but your score reflects your learning that's a general understanding and if you're not learning well there is some issue okay which you need to act on okay it could be that you're not putting effort you're not putting efforts or it could be that you are not able to access your materials or the teacher is not teaching well or other issues okay you you're constrained on your time whatever so there is a problem which the score helps you act on the problem okay so that is how risk management also work you identify assess and then control okay so that this is the sort of approach okay and let me share one screen with you so that you know this are you able to see my screen yes sir which is a PowerPoint yes sir okay so here I have shown a formula okay this is the final formula for calculating risk okay it looks like an equation okay residual risk which is equal to loss frequency in the loss magnitude plus measurement uncertainty okay and I have made a correction of the previous formula which was given in the lecture okay in the video lecture you will see the formula that is given at the bottom okay I've made a small correction to make it simple okay so so this formula help us understand how risk is assessed okay so risk

is calculated based on primarily based on two factors one is loss frequency other is loss magnitude okay so loss frequency if you go back to your lessons you will find that loss frequency is a measure that emerges from two probabilities two probabilities one is the probability or here the term likelihood is used okay there is slight difference between likelihood and probability but here I am using it in a similar sense but essentially meaning what is the probability of an attack okay so therefore it recognizes that there are a lot of threads okay internal and external threats okay each of these threads has a probability they are not equal in terms of the likelihood of occurrence okay so likelihood of something happening okay an attack happening okay that is something that has to be available as a data okay and we also know that credit intelligence is something that is a that is a very informed activity and it requires expertise oftentimes external expertise okay so this data has to come from experts okay threat intelligence expertise so there is a probability which is about the likelihood of an attack and there is also that probability is combined with or multiplied with okay the likelihood of success of that attack okay likelihood of success of that attack so likelihood of success it depends on vulnerability okay so therefore for each thread there is a corresponding vulnerability for example you have already invested in people process technology to Define your system to protect your systems and therefore in certain cases for certain attack you may be completely prepared to defend yourself and therefore the likelihood of success is very low the likelihood of attack this axis but the likelihood of success is very low because you already have defense mechanisms in place so you multiply both the frequencies of both the probabilities and that is known as loss frequency okay what is the likelihood that there will be a successful attack that is what loss frequency is so it's a probability okay and then there is loss magnitude loss magnitude talks about impact if an attack happens what is your exposure okay how much loss what is the probability of loss or sorry what is the loss okay what is exactly is the loss or that is that is again in in in the video you can see or the lecture you can see you have objective measure of impact okay it can be in a scale of say 0 to 100 or it could be in any objective measurement scale that that the impact is assessed and then you have impact but if an equipment is attacked sometimes it is not the whole equipment that gets affected it could be part okay that a part of that equipment or a server or a system may be down and therefore you call it exposure what percentage of a particular asset is exposed okay that is what loss magnitude is so when you multiply probability with impact okay then you get a risk a measure of risk okay loss frequency into loss magnitude is nothing but probability into impact okay so a general formula for risk is probability of occurrence into impact if it occurs okay so that is calculated in a more detailed way in cyber security risk assessment using two measures known as low frequency and low magnitude okay but when you do this measurement we recognize that the measurement always has error okay because these measurements are not you know very objective measurements these are also measurements which are perceptual for example the probability maybe the Judgment of an expert okay so there could be judgment error okay even the magnitude or exposure Etc are also oftentimes perceptual measures and therefore there is likelihood of error and if and that is the reason why we add a another factor or another item to this risk residual risk measurement known as measurement uncertainty okay measurement uncertainty is added because you want to amplify the risk you know you want to go with the worst case and therefore you are saying your measurement there may be

measurement error and it may not be measured accurately so I want to add one more factor to sort of Step It Up to show risk is higher than what is measured because there is uncertainty and next in the next slide you must be seeing an example and that example illustrates how risk measurement in practice is done using this formula okay and that gives you a sense of how to also factor in measurement uncertainty okay and I have revised the formula here to remove the confusion of one item in the previous formula even in your new textbook new edition of the textbook they have removed this minus the percentage of risk mitigated by current controls okay so well this formula is very fine grained if you add that for example after the assessment has been done if there are extra measures taken to reduce risk then you are trying to subtract that from the formula okay so that your final measure of residual risk will be very accurate but so you can see in the class when it is going on there is a confusion about this term okay so let's assume that the assessment of loss frequency and lowest magnitude are done when certain controls are set in place and after these measures have been taken there is no additional measure okay that is taken to many to further minimize risk okay and with that assumption we remove this item from the formula and make it more simple and straightforward so you and also in the example that we discussed we can see that there is no such Factor coming in okay so for all practical purposes the formula for residual risk can be treated as low frequency into loss magnitude plus measurement uncertainty okay so I just wanted to add this as one lesson because there is some confusion coming up because of this factor in the formula and it is not well understood and you know even the textbook has made a correction on it I think this is pretty clear if you let me check the chat box if there are some questions coming in okay week seven so somebody has asked a cervix 7 assignment and the interaction lectures with the industry person has no one-to-one correspondence well the industry invited lecture was conducted in the classroom and students do ask questions and they also participate and the video captures the whole of it okay and therefore I did not understand what you're saying if you want to reframe your question what is your specific concern Aisha you can put that up in the chat box again okay and let me stop sharing and then also look at some of the specific questions that has come up in the discussion forum compiled by binod okay I have posted reading materials before I forget for the next this week and the next two weeks that is week six seven and eight okay so essentially you will see that you have to read chapter 5 6 7 and 8 of the textbook so what I want to question you is text chapter 6 to 8 okay so you may have questions from chapter six to eight during this coming weeks okay particularly seven weeks seven and week eight chapter six is of course risk management that is the current week and seven and eight will be covered in the lectures of the subsequent week foreign why I a six seven and eight okay sorry chapter five is for risk management sorry six seven and eight are covered for lectures seven and eight okay let me say that again there are three chapters included for two weeks which is week seven and week eight and therefore please read that and you may also see that there will be some overlaps in terms of Concepts among these three chapters and therefore it is always good to read all the three chapters in advance okay and when you answer your assignments okay you may find some overlaps okay and then you may start questioning us saying that well this was not included in the specific chapter but it belonged to the previous week or subsequent week Etc because the reason is many of these Concepts actually flow on certain topics okay so unless you know the previous one you cannot

go to the next one and hence read them together and be prepared that a question from chapter 6 or chapter seven maybe there in week seven okay or at chapter eight maybe partially contained in the lecture of week seven and so we may ask those questions okay so please read six to eight together okay so that in your assignments you will not have a problem okay although I separated these chapters for different weeks that is a sort of approximation okay you need all the three chapters to understand cyber security Technologies okay so the discussion is about cyber security technology so I especially for this is from the perspective of the assignments okay so let me go to some of the recurring questions that is coming up that is you have questions about what happens if I miss an assignment what qualifies me for the final examination would I be not able to give exams so this again I say these are issues related to the platform and its rules which are already mentioned in the announcement please go and read the announcement very well what is the minimum requirement for qualifying to give the final examination please read in the announcement which is already there okay and if I miss one assignment can I give the next assignment yes you can okay but about the final examination please read us announcement okay okay okay somebody asked this is a practice based course or only Theory course I want to clarify it again this is a theory course there is no laboratory exercise that is involved in this course okay there is no lab there is no experiment or anything of that kind it is it is done in lecture mode and using reading materials and therefore it's a theory course so textbook has already been discussed many times what is the textbook and it's available in the announcement also please look at that and buy your textbook from and buy online from Flipkart or Amazon is hardly cost about 300 or 400 rupees please do that without that you cannot give exams or really understand Concepts a lot more than what is covered in the lectures are covered in the textbook a lot more in the sense they are complementary okay I am in third year engineering student can I apply for an examination and also get certificate of this course I already said this is a postgraduate course and I discourage undergraduate students from taking this course but nothing prevents you from attending the lectures but to I discourage students from getting certified because it's a PG course and you are in ug okay based on that logic but if you are interested nothing prevents you actually from taking the course okay and you're already taking the course and of course there are a couple of issues with week three assignment and week five assignment week three is being re-evaluated and it must be done already I believe week five participants has spotted one issue which is with question number three and we have gone through it thoroughly and we understand there is incomplete options given you are right and actually we are dropping that question because of that issue because some have taken it some have not taken it etcetera to remove that sort of a confusion and we will not consider question number three in the evaluation okay and thank you for supporting this and Reporting this let me look at the chat box if there are other questions how to get job after this course okay I do not know you have to actually look at employment opportunities and this is a course that of course you can add to your CV and you need to have of course knowledge if you get a call for an interview and of course respond to questions okay this is not job training but of course it helps you with your career foreign somebody says question number two is also wrong in solution no nobody has complained it but we have of course vetted this question each week's question paper and very unlikely that there is any other error of course there can be errors we can of course check that

again but very unlikely okay is there any other technical question any question that is related to the course or Contents I will be more than happy to clarify please read the textbook thoroughly chapter five which is for this week on risk management and get your Concepts clear in terms of how risk assessment is done okay and that will help you in different job functions because it also gives you a sense of what is generally risk okay you will see that there is a template called TVA right the DBA worksheet which is about asset and vulnerable asset and a set wise thread okay thread on the vertical axis assets on the horizontal axis and then you have vulnerability for each combination of a set and asset and threads okay assets and threads okay threat works against assets so asset is the unit okay and that is one unit and threat is another unit and then you assess vulnerability for each combination okay and of course when you sort and do it it actually comes in the ascending order okay and it is for each vulnerability that you try to understand what is the likelihood okay of success of attack okay it is based on vulnerabilities okay so it becomes extremely clear to you when you go through this lesson on this customer okay okay if there are no further questions I will close here and have a great Happy week and I look forward to seeing you next week all right thank you and see you next week okay thank you we'll close it here okay there are questions coming up about question two or week five we've been since you raising this concern we will definitely check this and get back okay thank you okay see you next week thank you